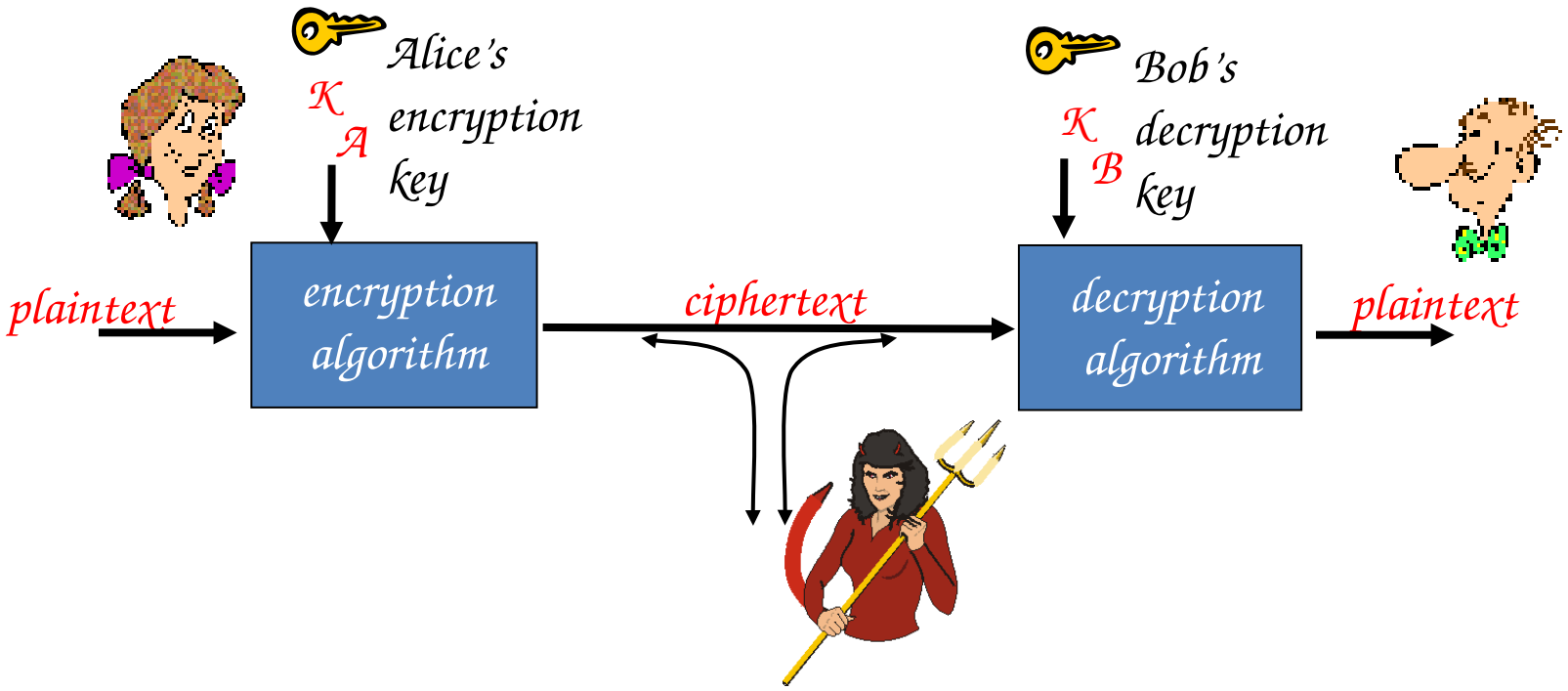
Cryptography

The language of cryptography

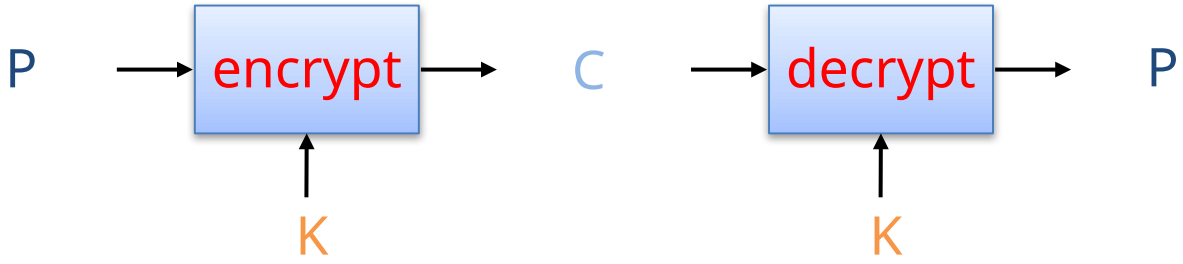


symmetric key crypto: sender, receiver keys *identical*

public-key crypto: encryption key *public*, decryption key *secret* (private)

Symmetric Cryptosystem

- Scenario
  - Alice wants to send a message (plaintext P) to Bob.
  - The communication channel is insecure and can be eavesdropped
  - If Alice and Bob have previously agreed on a symmetric encryption scheme and a secret key K, the message can be sent encrypted (ciphertext C)
- Issues
  - What is a good symmetric encryption scheme?
  - What is the complexity of encrypting/decrypting?
  - What is the size of the ciphertext, relative to the plaintext?

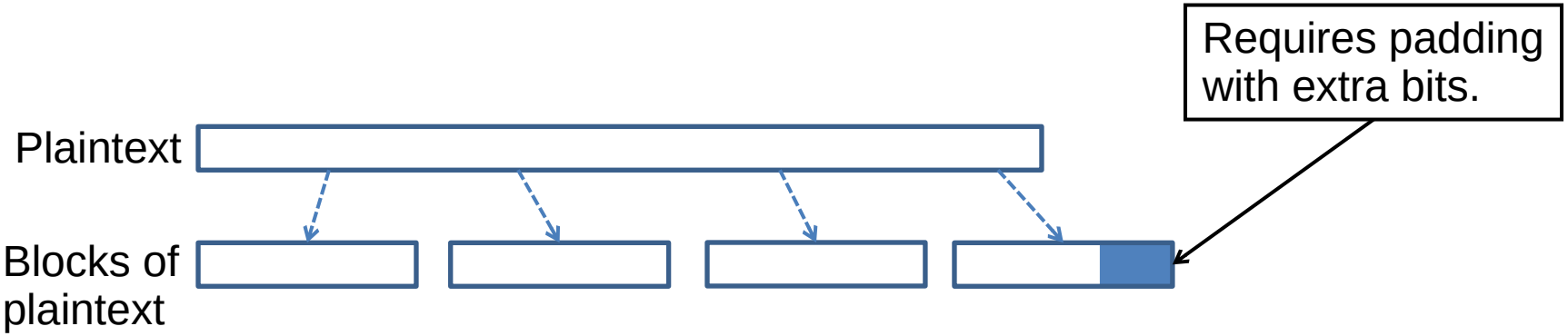


Basics

- Notation
  - Secret key K
  - Encryption function $E_K(P)$
  - Decryption function $D_K(C)$
  - Plaintext length typically the same as ciphertext length
  - Encryption and decryption are one-one mapping functions on the set of all n-bit arrays
- Efficiency
  - functions E_K and D_K should have efficient algorithms
- Consistency
  - Decrypting the ciphertext yields the plaintext
  - $D_K(E_K(P)) = P$

Block Ciphers

- In a **block cipher:**
  - Plaintext and ciphertext have fixed length bit (e.g., 128 bits)
  - A plaintext of length n is partitioned into a sequence of m **blocks**, P[0], …, P[m 1], where n bm n + b
- Each message is divided into a sequence of blocks and encrypted or decrypted in terms of its blocks.



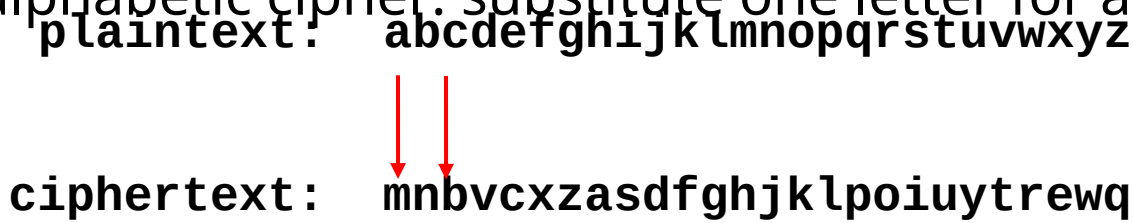
Block Ciphers in Practice

- Data Encryption Standard (DES)
  - Developed by IBM and adopted by NIST in 1977
  - 64-bit blocks and 56-bit keys
  - Small key space makes exhaustive search attack feasible since late 90s
- Triple DES (3DES)
  - Nested application of DES with three different keys KA, KB, and KC
  - Effective key length is 168 bits, making exhaustive search attacks unfeasible
  - $C = E_{KC}(D_{KB}(E_{KA}(P)))$; $P = D_{KA}(E_{KB}(D_{KC}(C)))$
  - Equivalent to DES when KA=KB=KC (backward compatible)
- Advanced Encryption Standard (AES)
  - Selected by NIST in 2001 through open international competition and public discussion
  - 128-bit blocks and several possible key lengths: 128, 192 and 256 bits
  - Exhaustive search attack not currently possible
  - AES-256 is the symmetric encryption algorithm of choice

Symmetric key cryptography

substitution cipher: substituting one thing for another

- monoalphabetic cipher: substitute one letter for another



E.g.:

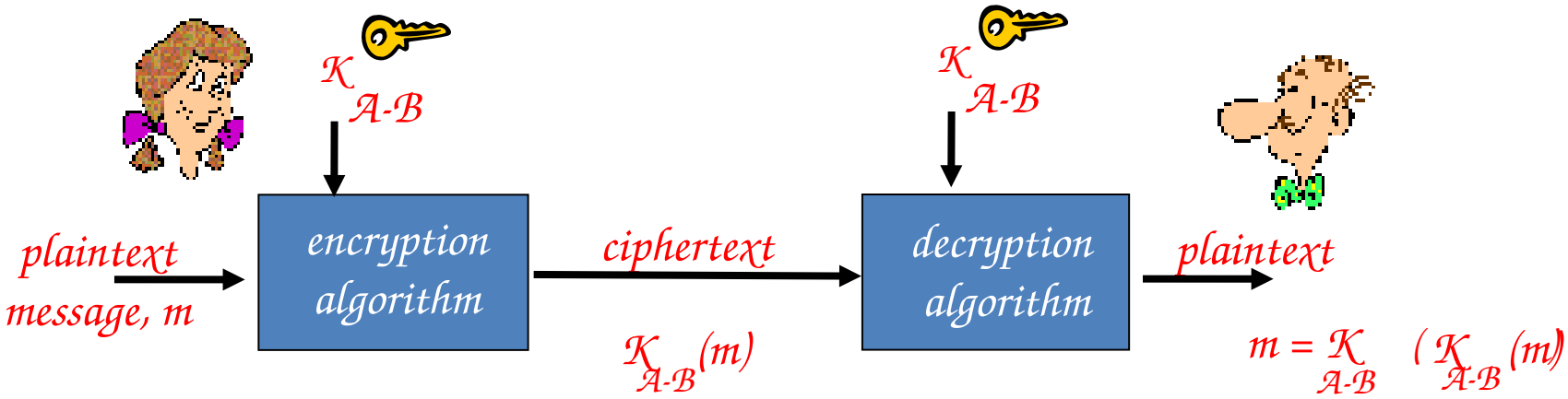
Plaintext: bob. i love you. alice

ciphertext: nkn. s gktc wky. mgsbc

Q: How hard to break this simple cipher?:

- *brute force (how hard?)*
- *other?*

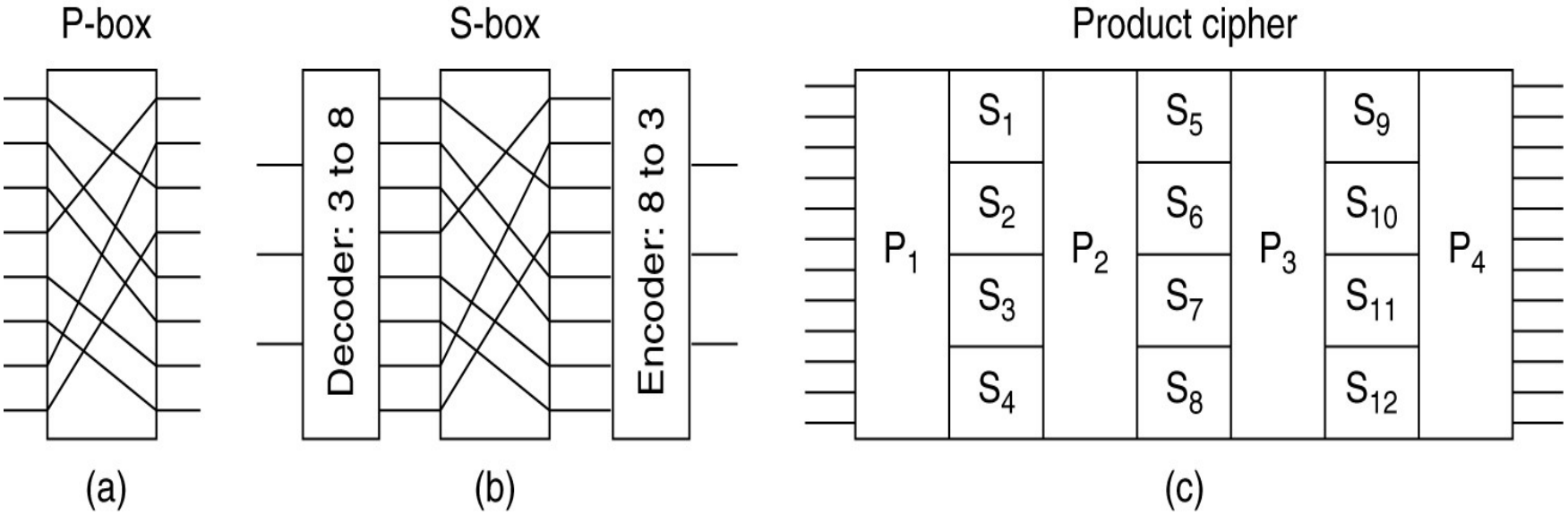
Symmetric key cryptography



symmetric key crypto: Bob and Alice share know same (symmetric) key: $K_{A\text{-}B}$

- e.g., key is knowing substitution pattern in mono alphabetic substitution cipher
- Q: how do Bob and Alice agree on key value?

Product Ciphers



Basic elements of product ciphers. (a) P-box. (b) S-box. (c) Product.

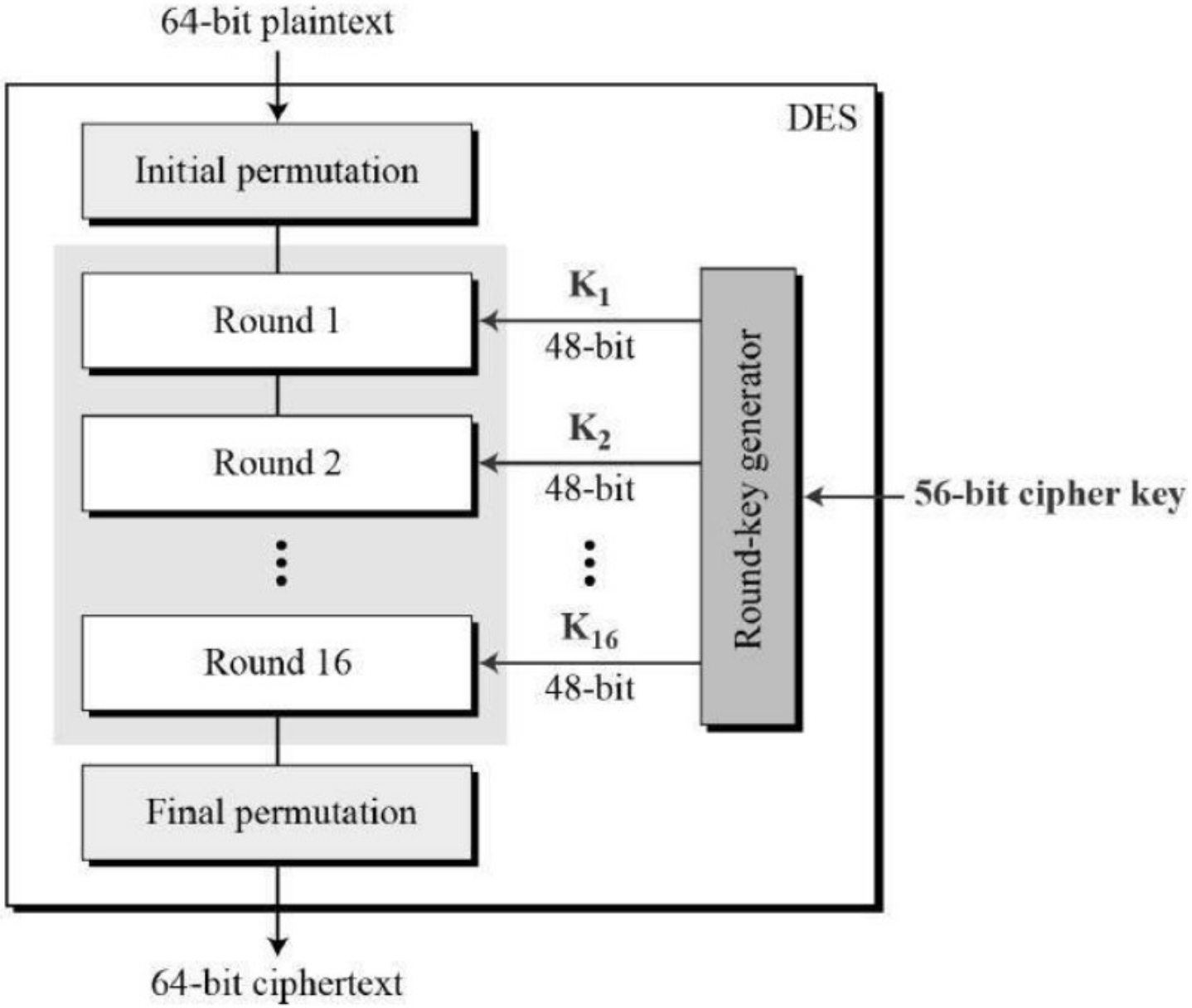
- S-boxes are non-linear transformations of a few input bits that provide confusion and
- P-boxes simply shuffle the input bits around to provide diffusion

Symmetric key crypto: DES

DES: Data Encryption Standard

- US encryption standard [NIST 1993]
- 56-bit symmetric key, 64-bit plaintext input
- How secure is DES?
  - DES Challenge: 56-bit-key-encrypted phrase ("Strong cryptography makes the world a safer place") decrypted (brute force) in 4 months
  - no known "backdoor" decryption approach
- making DES more secure:
  - use three keys sequentially (3-DES) on each datum
  - use cipher-block chaining

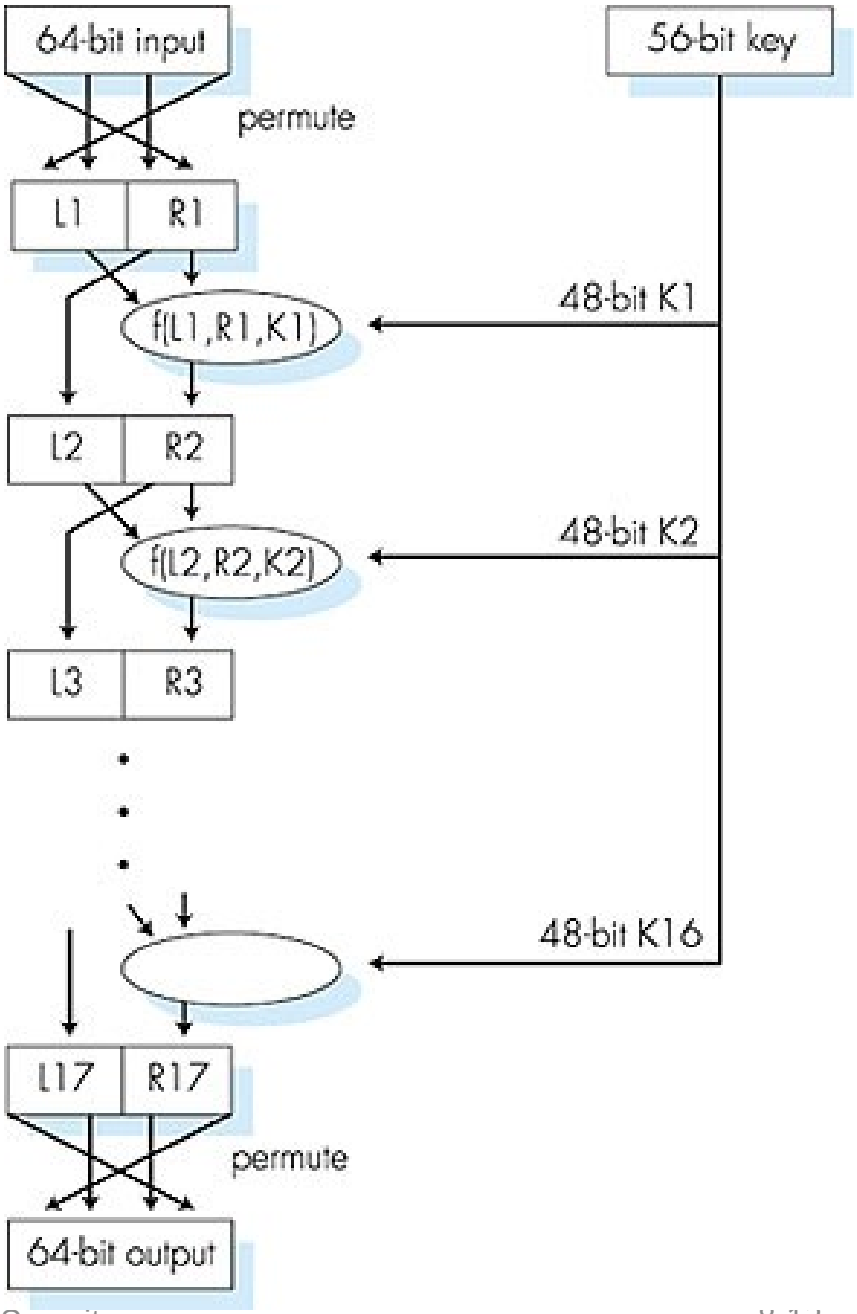
DES


64-bit plaintext
DES
Initial permutation
Round 1
Round 2
Round 16
Final permutation
K_1
48-bit
K_2
48-bit
K_{16}
48-bit
Round-key generator
56-bit cipher key
64-bit ciphertext

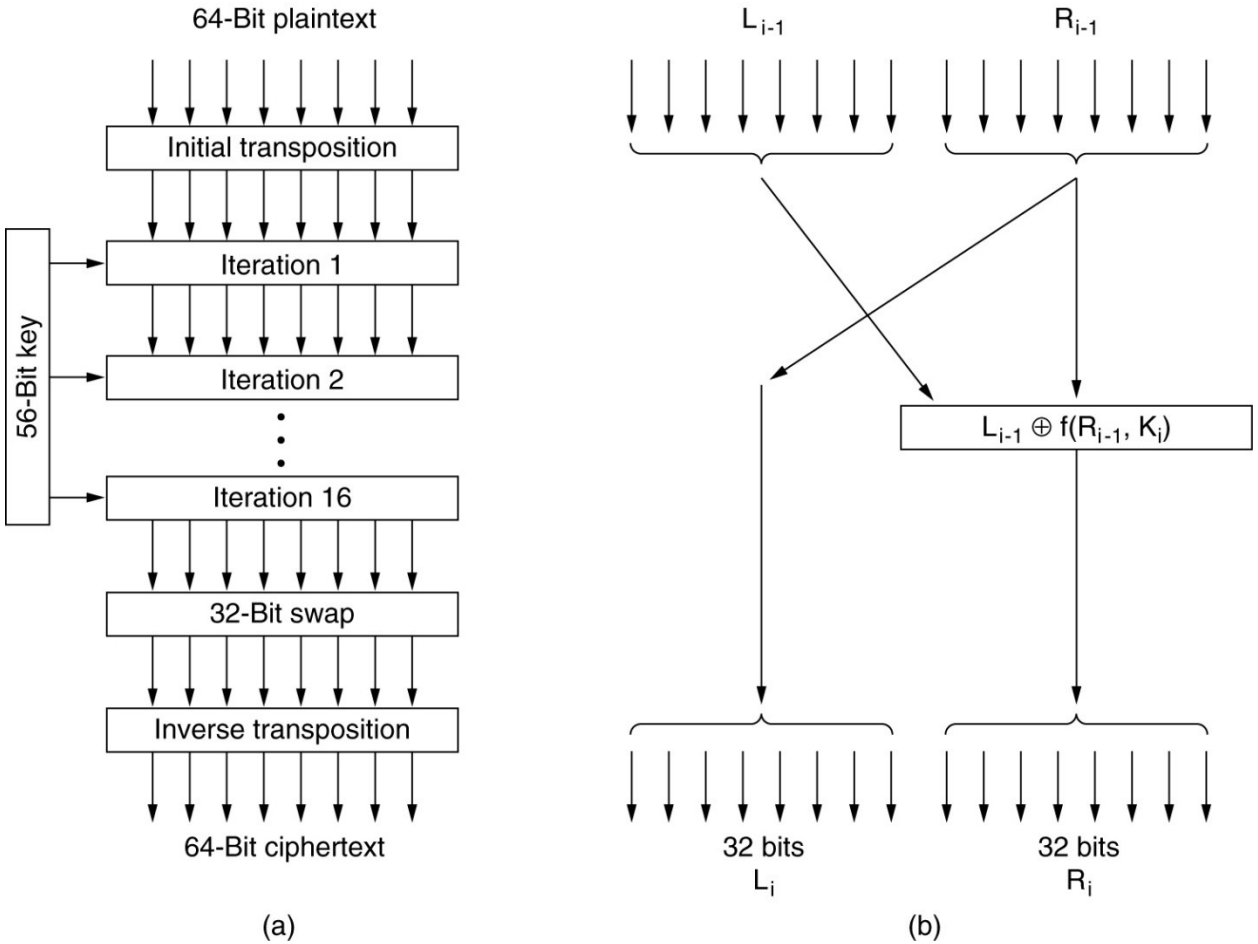
Symmetric key crypto: DES

DES operation

- Initial permutation
- 16 identical "rounds" of function application, each using different 48 bits of key
- Final permutation

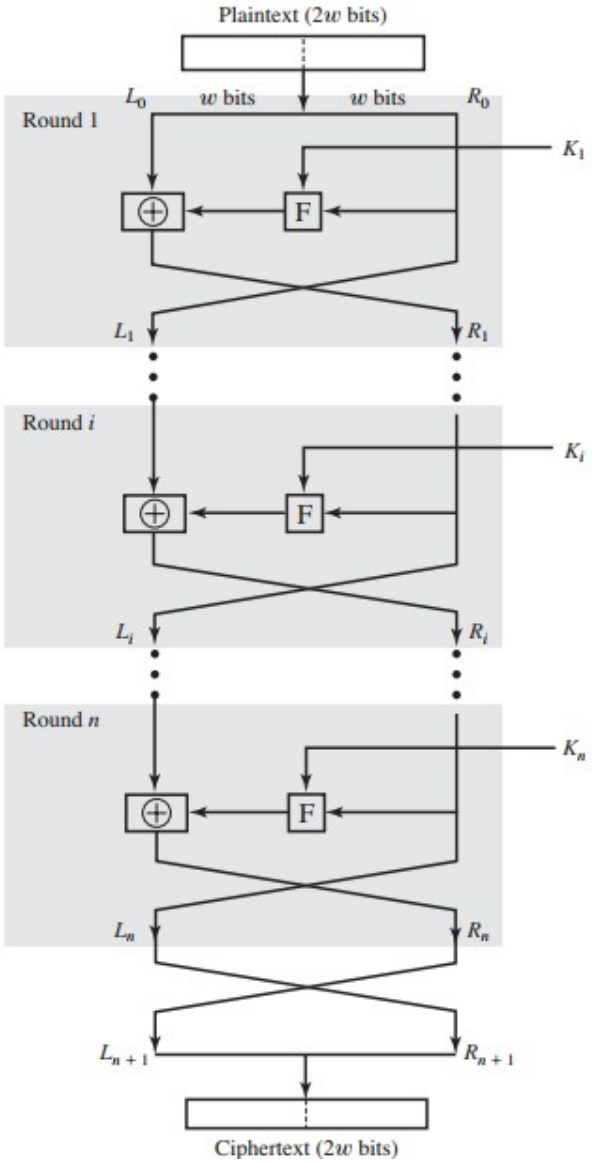


Data Encryption Standard

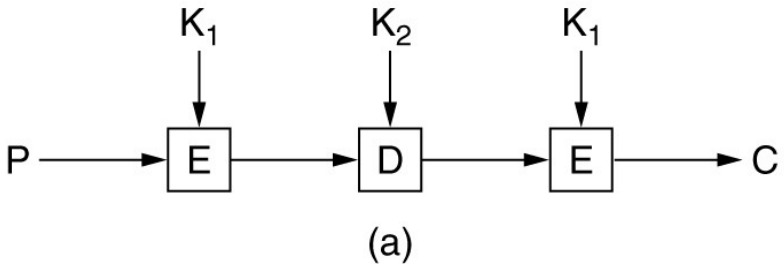


The data encryption standard. (a) General outline.
(b) Detail of one iteration. The circled + means exclusive OR.

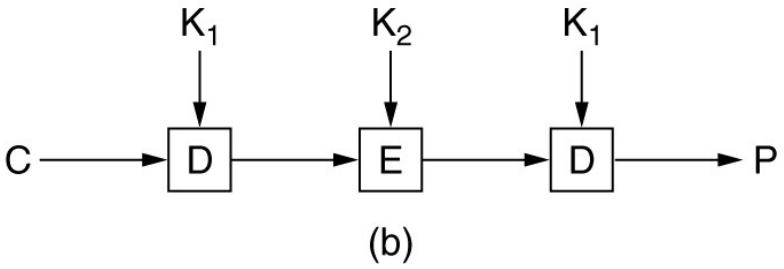
Classical Fiestal Network



Triple DES



(a) Triple encryption using DES.

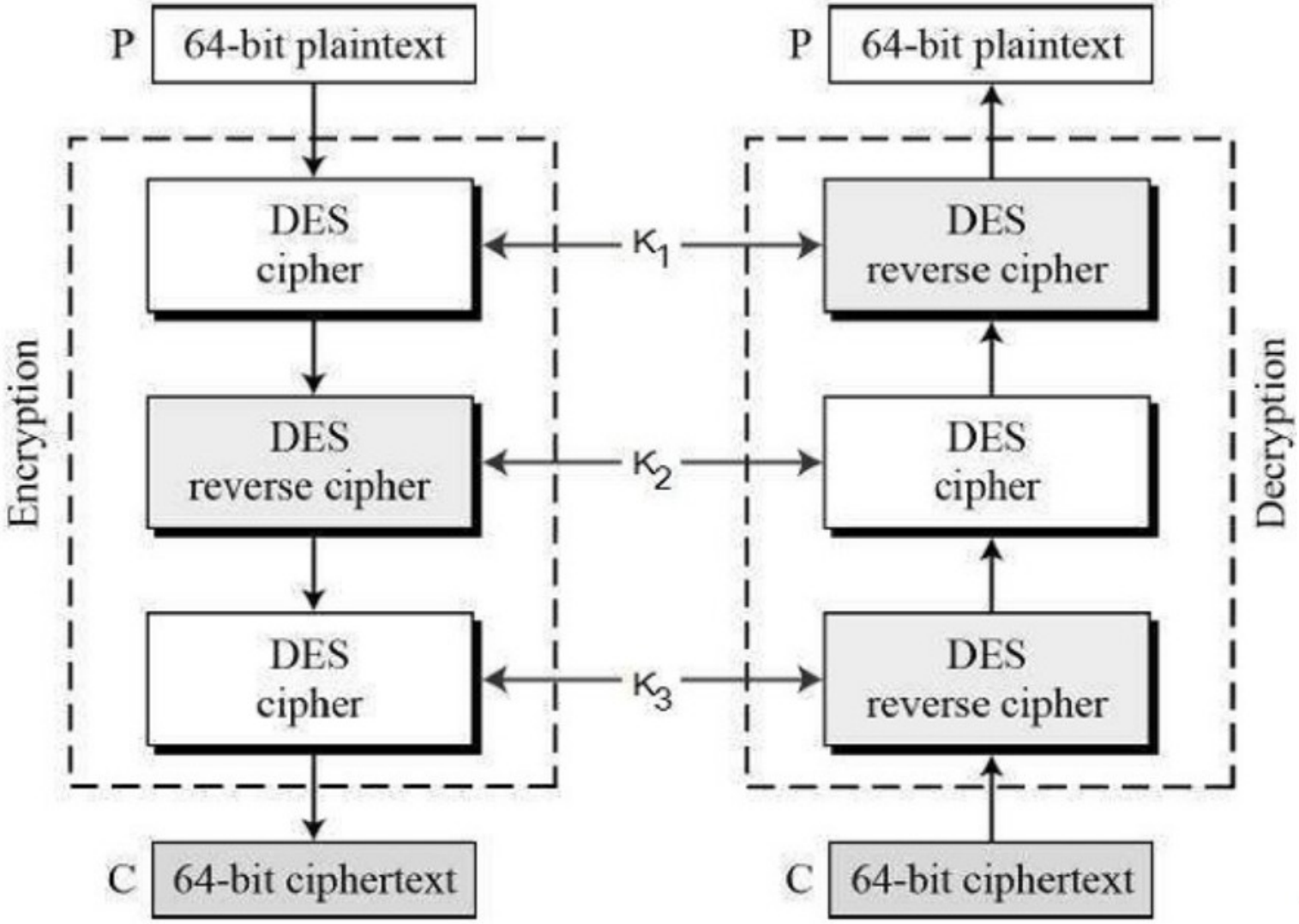


(b) Decryption.

3DES

- It is a block cypher used to encrypt data in 64-bit blocks.
- It is a symmetric encryption algorithm
- Uses multiple rounds of the Data Encryption Standard (DES) to improve security.
- Takes three times to encrypt its data.
- Security-wise, it outperforms the original DES
- 3DES is less efficient and slower than AES

3DES

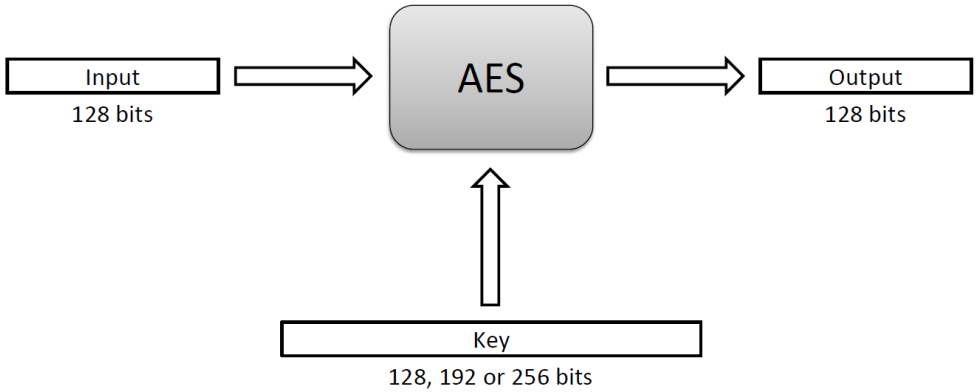

P
64-bit plaintext
DES cipher
DES reverse cipher
DES cipher
C
64-bit ciphertext
Encryption
K1
K2
K3
P
64-bit plaintext
DES reverse cipher
DES cipher
DES reverse cipher
C
64-bit ciphertext
Decryption

AES: Advanced Encryption Standard

- Symmetric-key NIST standard, replacing DES
- Security strength equal to or better than 3DES
- Improved efficiency
- Brute force decryption (try each key) taking 1 sec on DES, takes 149 trillion years for AES

AES

- Symmetric block cipher, block length 128 bits
- Key lengths 128, 192, and 256 bits
- Evaluation include security, computational efficiency, memory requirements, hardware and software suitability, and flexibility
- 2001, AES issued as federal information processing standard (FIPS 197)

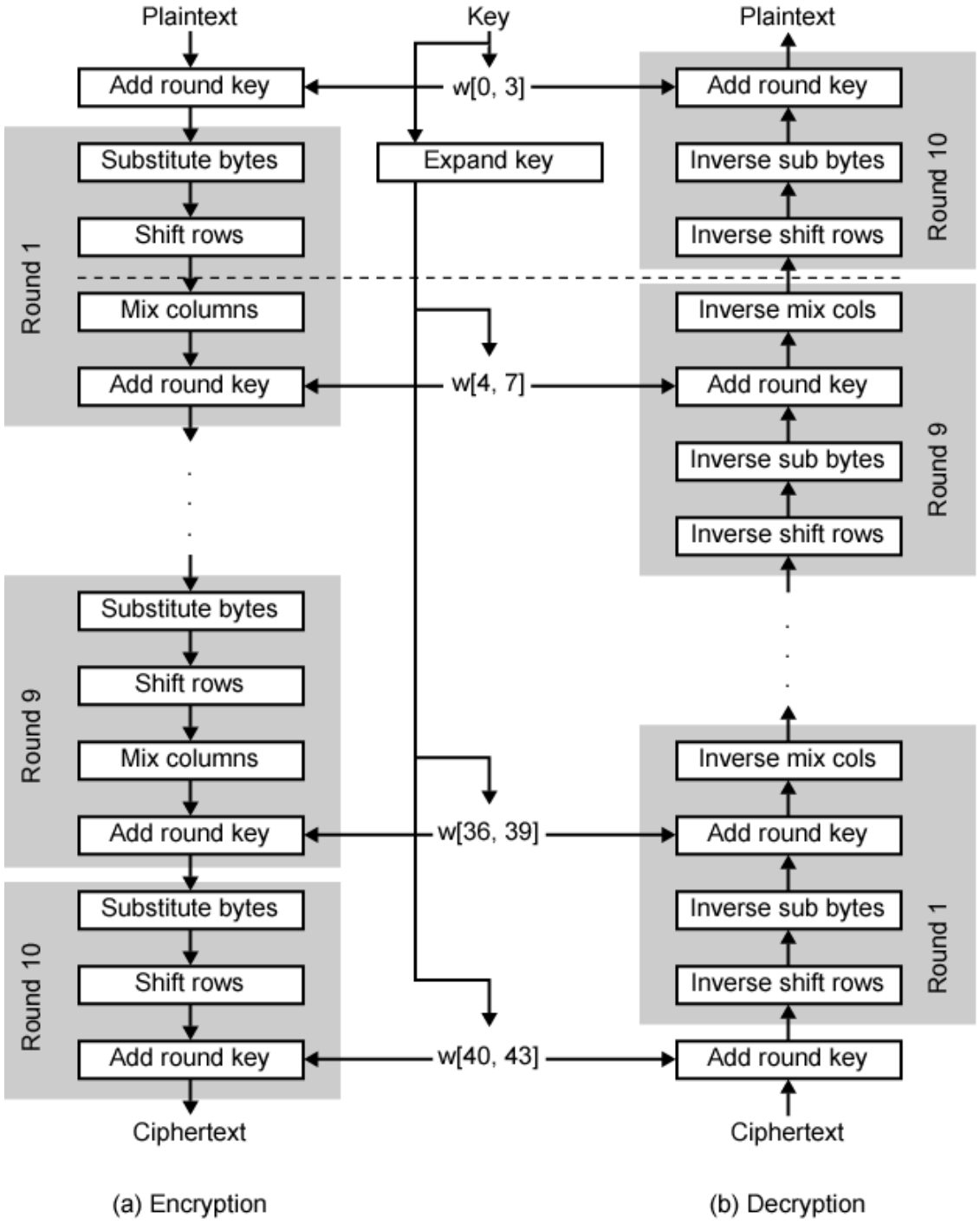


- https://en.wikipedia.org/wiki/Advanced_Encryption_Standard

Steps of AES

- Assume key length 128 bits
- Input is single 128-bit block
  - Depicted as square matrix of bytes
  - Block copied into State array
    - Modified at each stage
  - After final stage, State copied to output matrix
- 128-bit key depicted as square matrix of bytes
  - Expanded into array of key schedule words
  - Each four bytes
  - Total key schedule 44 words for 128-bit key
- Byte ordering by column
  - First four bytes of 128-bit plaintext input occupy first column of in matrix
  - First four bytes of expanded key occupy first column of w matrix

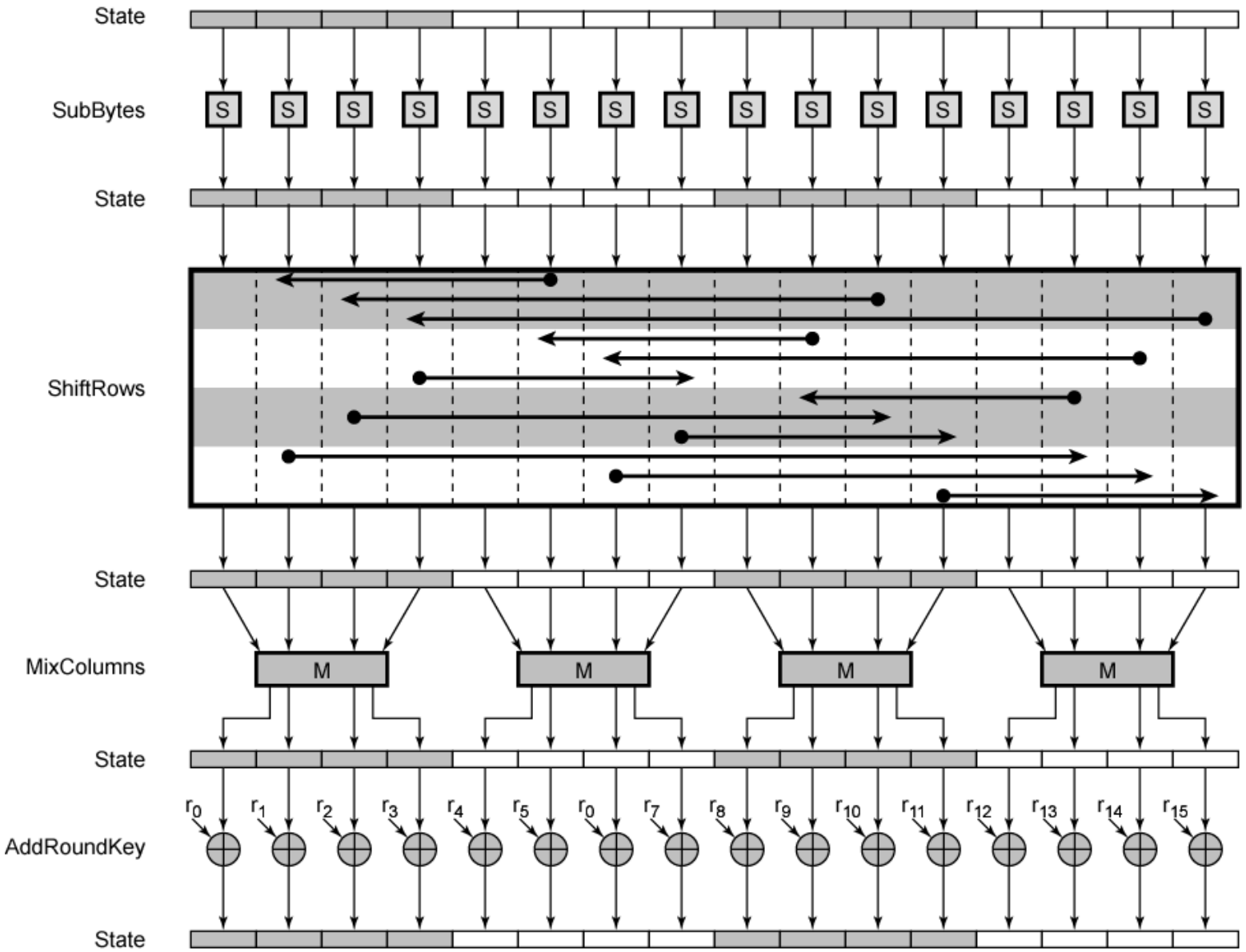
AES Encryption and decryption



AES

- Key expanded into array of forty-four 32-bit words, w[i]
  - Four distinct words (128 bits) serve as round key for each round
- Four different stages
  - One permutation and three substitution
    - Substitute bytes uses S-box table to perform byte-by-byte substitution of block
    - Shift rows is permutation that performed row by row
    - Mix columns is substitution that alters each byte in column as function of all of bytes in column
    - Add round key is bitwise XOR of current block with portion of expanded key
- Simple structure
  - For both encryption and decryption, cipher begins with Add Round Key stage
  - Followed by nine rounds,
    - Each includes all four stages
  - Followed by tenth round of three stages

AES Encryption Round

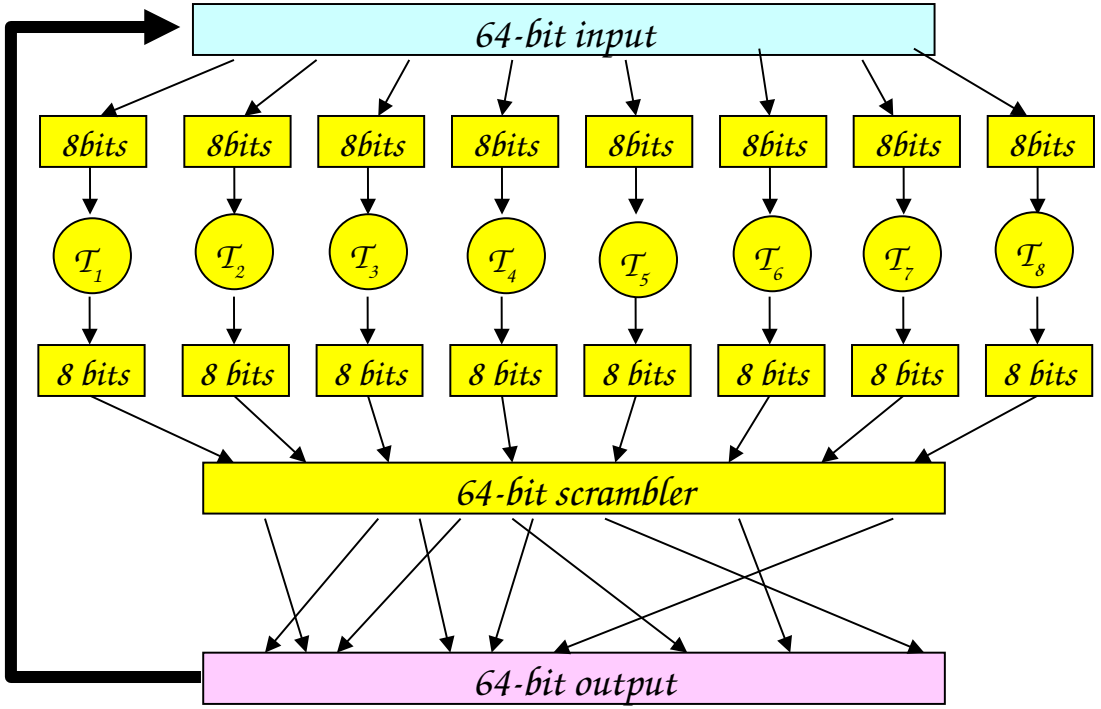


Symmetric Encryption Algorithms

	DES	Triple DES	AES
Plaintext block size (bits)	64	64	128
Ciphertext block size (bits)	64	64	128
Key size (bits)	56	112 or 168	128, 192, or 256

DES = Data Encryption Standard
AES = Advanced Encryption Standard

Block Cipher

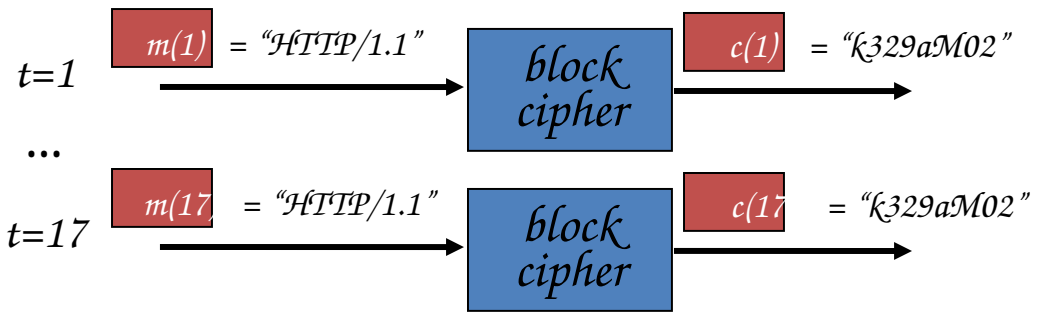


- one pass through: one input bit affects eight output bits

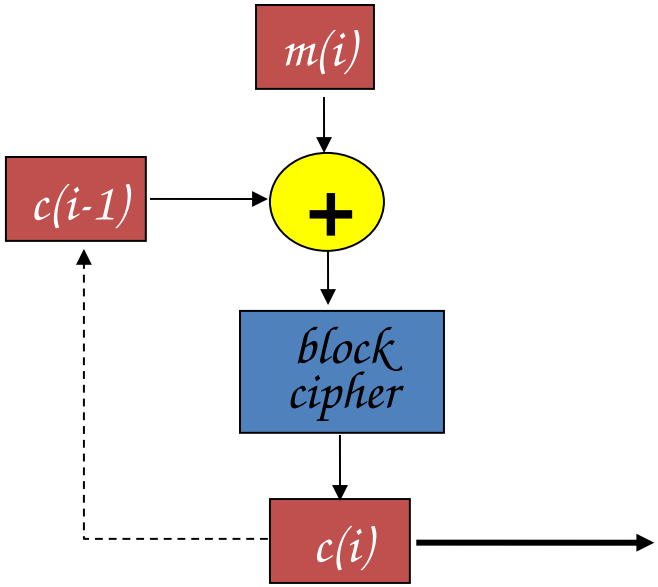
- *multiple passes: each input bit afects all output bits*
- *block ciphers: DES, 3DES, AES*

Cipher Block Chaining

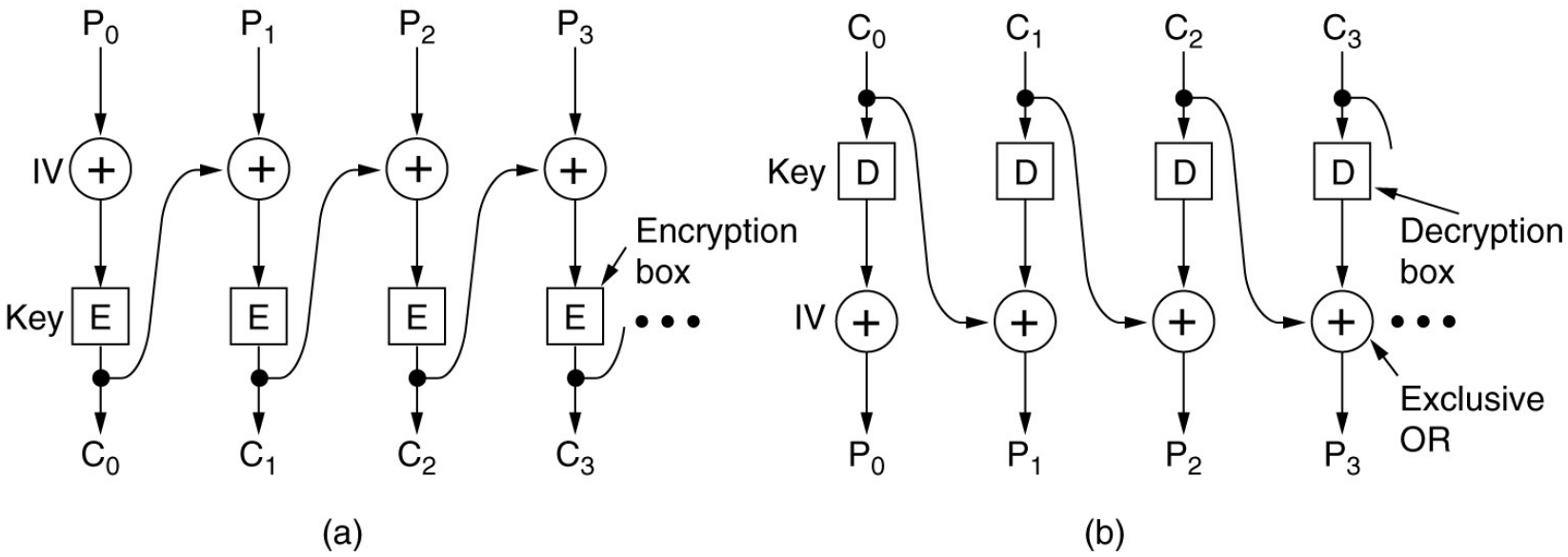
- cipher block: if input block repeated, will produce same cipher text:



- *cipher block chaining: XOR ith input block, m(i), with previous block of cipher text, c(i-1)*
  - *c(0) transmitted to receiver in clear*
  - *what happens in "HTTP/1.1" scenario from above?*



Cipher Block Chaining Mode



(a) Encryption.

(b) Decryption.

Strengths and Weaknesses of CBC

- Strengths:
  - Doesn’t show patterns in the plaintext
  - Is the most common mode
  - Is fast and relatively simple
- Weaknesses:
  - CBC requires the reliable transmission of all the blocks sequentially
  - CBC is not suitable for applications that allow packet losses (e.g., music and video streaming)

Modular Arithmetic

Division Algorithm

- **Division Algorithm**: If a is an integer and d a positive integer, then there are unique integers q and r, with $0 \leq r < d$, such that $a = dq + r$
  - d is called the *divisor*.
  - a is called the *dividend*.
  - q is called the *quotient*.
  - r is called the *remainder*.

Definitions of Functions **div** and **mod**

$q = a$ **div** d
$r = a$ **mod** d

Examples:

- What are the quotient and remainder when 101 is divided by 11?

  Solution: The quotient is 9 and the remainder is 2.

Congruence Relation

Definition: If *a* and *b* are integers and *m* is a positive integer, then *a* is *congruent* to *b modulo m* if *m* divides $a - b$

- The notation $a \equiv b \pmod{m}$ says that *a* is congruent to *b* modulo *m*.
- Two integers are congruent mod *m* if and only if they have the same remainder when divided by *m*.
- If *a* is not congruent to *b* modulo *m*, we write

  $a \not\equiv b \pmod{m}$

Example: Determine whether 17 is congruent to 5 modulo 6 and whether 24 and 14 are congruent modulo 6.

Solution:

- $17 \equiv 5 \pmod{6}$ because 6 divides $17 - 5 = 12$.
- $24 \not\equiv 14 \pmod{6}$ since $24 - 14 = 10$ is not divisible by 6.

More on Congruences

Theorem: Let m be a positive integer. The integers a and b are congruent modulo m if and only if there is an integer k such that $a = b + km$.

Proof:

- If $a \equiv b \pmod{m}$, then
  $m \mid a - b$.
- Hence, there is an integer k such that $a - b = km$ and equivalently $a = b + km$.
- Conversely, if there is an integer k such that $a = b + km$, then $km = a - b$. Hence, $m \mid a - b$ and $a \equiv b \pmod{m}$. ◀

Congruences of Sums and Products

Theorem 5: Let m be a positive integer. If $a \equiv b \pmod{m}$ and $c \equiv d \pmod{m}$, then

$a + c \equiv b + d \pmod{m}$ and

$ac \equiv bd \pmod{m}$

Proof:

- Because $a \equiv b \pmod{m}$ and $c \equiv d \pmod{m}$, by Theorem 4 there are integers s and t with $b = a + sm$ and $d = c + tm$.
- Therefore,
  - $b + d = (a + sm) + (c + tm) = (a + c) + m(s + t)$ and
  - $b\,d = (a + sm)(c + tm) = ac + m(at + cs + stm)$.
- Hence, $a + c \equiv b + d \pmod{m}$ and $ac \equiv bd \pmod{m}$. ◀

Example: Because $7 \equiv 2 \pmod{5}$ and $11 \equiv 1 \pmod{5}$, it follows from Theorem 5 that

$$18 = 7 + 11 \equiv 2 + 1 = 3 \pmod{5}$$

$$77 = 7 \bullet 11 \equiv 2 \bullet 1 = 2 \pmod{5}$$

Algebraic Manipulation of Congruences

- Multiplying both sides of a valid congruence by an integer preserves validity.

  If $a \equiv b \pmod{m}$ holds then $c \cdot a \equiv c \cdot b \pmod{m}$, where c is any integer, holds by Theorem 5 with $d = c$.

- Adding an integer to both sides of a valid congruence preserves validity.

  If $a \equiv b \pmod{m}$ holds then $c + a \equiv c + b \pmod{m}$, where c is any integer, holds by Theorem 5 with $d = c$.

- Dividing a congruence by an integer does not always produce a valid congruence.

Example: The congruence $14 \equiv 8 \pmod{6}$ holds. But dividing both sides by 2 does not produce a valid congruence since $14/2 = 7$ and $8/2 = 4$, but $7 \not\equiv 4 \pmod{6}$.

Primes

Definition: A positive integer *p* greater than 1 is called *prime* if the only positive factors of *p* are 1 and *p*.

A positive integer that is greater than 1 and is not prime is called *composite*.

Example: The integer 7 is prime because its only positive factors are 1 and 7, but 9 is composite because it is divisible by 3.

Prime Factorization

Theorem: Every positive integer greater than 1 can be written uniquely as a prime or as the product of two or more primes where the prime factors are written in order of nondecreasing size.

Examples:

- $100 = 2 \bullet 2 \bullet 5 \bullet 5 = 2^2 \bullet 5^2$
- $641 = 641$
- $999 = 3 \bullet 3 \bullet 3 \bullet 37 = 3^3 \bullet 37$
- $1024 = 2 \bullet 2 \bullet 2 \bullet 2 \bullet 2 \bullet 2 \bullet 2 \bullet 2 \bullet 2 \bullet 2 = 2^{10}$

Relatively Prime

Definition: The integers *a* and *b* are *relatively prime* if their greatest common divisor is 1.

Example: 17 and 22

Definition: The integers $a_1, a_2, \ldots, a_n$ are *pairwise relatively prime* if $\gcd(a_i, a_j) = 1$ whenever $1 \leq i < j \leq n$.

Example: Determine whether the integers 10, 17 and 21 are pairwise relatively prime.

Solution: Because $\gcd(10,17) = 1$, $\gcd(10,21) = 1$, and $\gcd(17,21) = 1$, 10, 17, and 21 are pairwise relatively prime.

Fermat’s Theorem

In number theory, **Fermat's little theorem** states that if *p* is a prime number, then for any integer *a*, the number $a^p - a$ is an integer multiple of *p*.

$$a^p \equiv a \pmod{p}$$

$$a^{p-1} \equiv 1 \pmod{p}.$$

https://en.wikipedia.org/wiki/Fermat%27s_little_theorem

Fermat's Theorem

Theorem 3: (*Fermat's Little Theorem*) If p is prime and a is an integer not divisible by p, then $a^{p-1} \equiv 1 \pmod{p}$

Furthermore, for every integer a we have $a^p \equiv a \pmod{p}$

Fermat's little theorem is useful in computing the remainders modulo p of large powers of integers.

Example: Find 7^{222} **mod** 11.

By Fermat's little theorem, we know that
$7^{10} \equiv 1 \pmod{11}$, and so $(7^{10})^k \equiv 1 \pmod{11}$, for every positive integer k.
Therefore,

$$7^{222} = 7^{22 \bullet 10 + 2} = (7^{10})^{22}\ 7^2 \equiv (1)^{22} \bullet 49 \equiv 5 \pmod{11}.$$

Hence, 7^{222} **mod** $11 = 5$.

Euler's theorem

- In number theory, **Euler's theorem** (also known as the Fermat–Euler theorem) states that, if *n* and *a* are coprime positive integers, then aφ(n) is congruent to 1 modulo *n:*

$$a^{\varphi(n)} \equiv 1 \pmod{n}$$

Public key cryptography

Symmetric key crypto

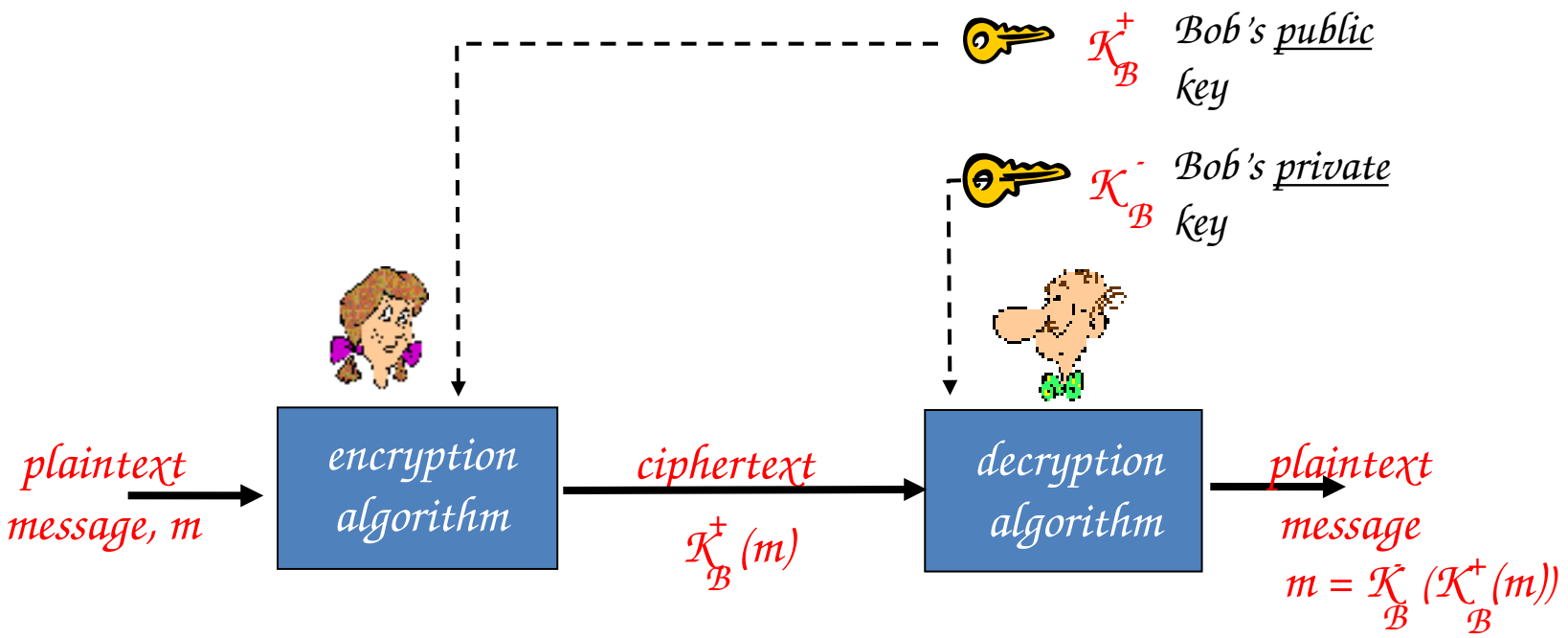
- requires sender, receiver know shared secret key
- Q: how to agree on key in first place (particularly if never "met")?

public key cryptography

- *radically different approach [Diffie-Hellman76, RSA78]*
- *sender, receiver do not share secret key*
- *public encryption key known to all*
- *private decryption key known only to receiver*



Public key cryptography



Public key encryption algorithms

Requirements:

1. need $K_B^+(\ )$ and $K_B^-(\ )$ such that $K_B^-(K_B^+(m)) = m$

2. *given public key* K_B^+*, it should be impossible to compute private key* K_B^-

RSA: Rivest, Shamir, Adleman algorithm

RSA: Choosing keys

1. *Choose two large prime numbers p, q.*
   (e.g., 1024 bits each)

2. *Compute n = pq, z = (p-1)(q-1)*

3. *Choose e (with e<n) that has no common factors with z. (e, z are "relatively prime").*

4. *Choose d such that ed-1 is exactly divisible by z.*
   (in other words: ed mod z = 1).

5. *Public key is (n,e). Private key is (n,d).*

K_B^+ K_B^-

RSA: Encryption, decryption

0. *Given (n,e) and (n,d) as computed above*

1. *To encrypt bit pattern, m, compute*

$c = m^e \bmod n$ *(i.e., remainder when m is divided by n)* ^{e}

2. *To decrypt received bit pattern, c, compute*

$m = c^d \bmod n$ *(i.e., remainder when c is divided by n)* ^{d}

Magic happens!

$$m = \underbrace{(m^e \bmod n)^d}_{c} \bmod n$$

RSA example

Bob chooses p=5, q=7. Then n=35, z=24.

e=5 (so e, z relatively prime).
d=29 (so ed-1 exactly divisible by z.

	letter	*m*	m^e	$c = m^e \bmod n$
encrypt:	l	12	1524832	17

	c	c^d	$m = c^d \bmod n$	*letter*
decrypt:	17	481968572106750915091411825223071697	12	l

RSA: another important property

The following property will be very useful later:

$$K_B^-\left(K_B^+(m)\right) = m = K_B^+\left(K_B^-(m)\right)$$

use public key first, followed by private key

use private key first, followed by public key

Result is the same!

Message Integrity

Message Integrity

Bob receives msg from Alice, wants to ensure:

- message originally came from Alice
- message not altered since sent by Alice

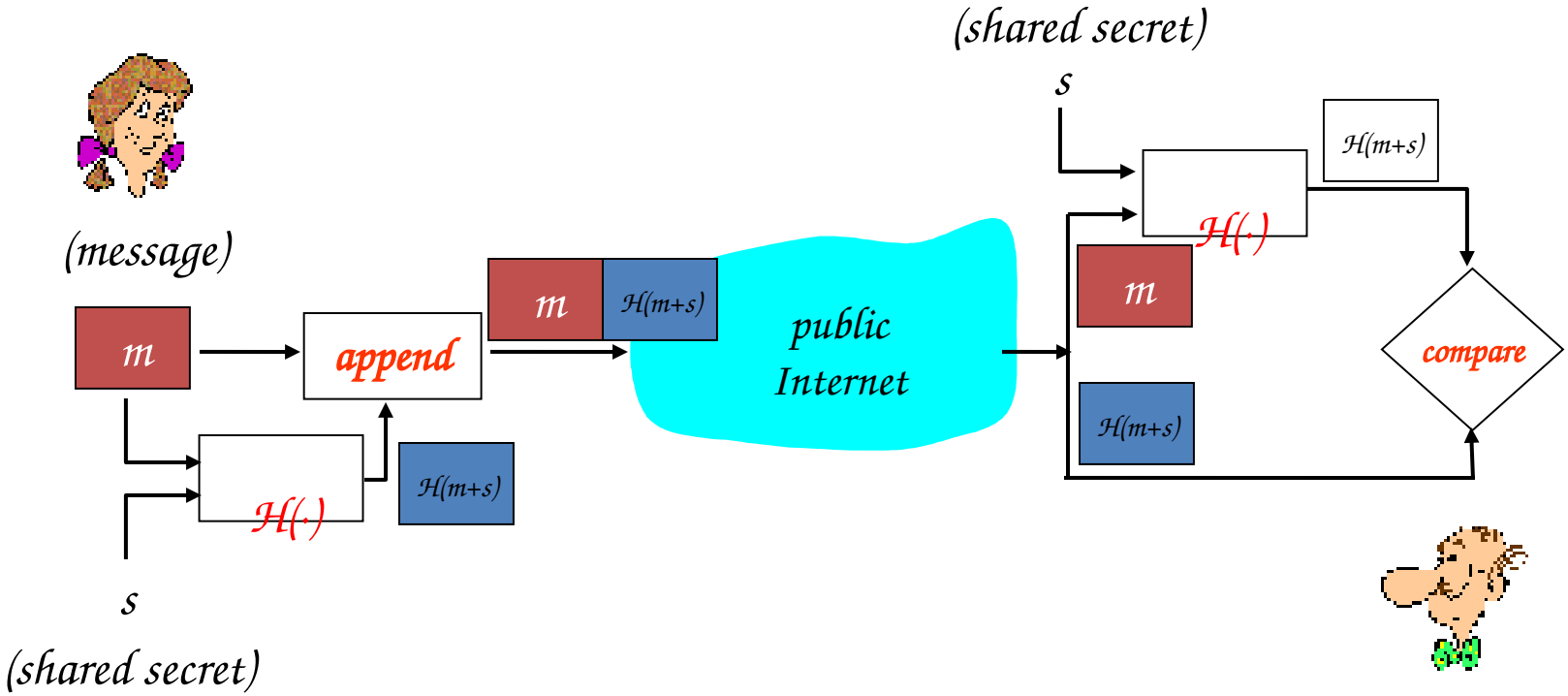
Cryptographic Hash:

- takes input m, produces fixed length value, H(m)
  - e.g., as in Internet checksum
- Computationally infeasible to find two different messages, x, y such that H(x) = H(y)
  - equivalently: given m = H(x), (x unknown), can not determine x.

Cryptographic Hash Functions

- Satisfies additional properties
  - one-way
    - Given a hash value x, it is hard to find a plaintext P such that h(P) = x
  - Weak collision resistance
    - Given a plaintext P, it is hard to find a plaintext Q such that h(Q) = h(P)
  - Collision resistance (aka strong collision resistance)
    - It is hard to find a pair of plaintexts P and Q such that h(Q) = h(P)
- Hash values of at least 256 bits recommended to defend against brute-force attacks

Message Authentication Code



MACs in practice

- MD5 hash function widely used (RFC 1321)
  - computes 128-bit MAC in 4-step process.
  - arbitrary 128-bit string x, appears difficult to construct msg m whose MD5 hash is equal to x
    - recent (2005) attacks on MD5
- SHA-1 is also used
  - US standard [NIST, FIPS PUB 180-1]
  - 160-bit MAC

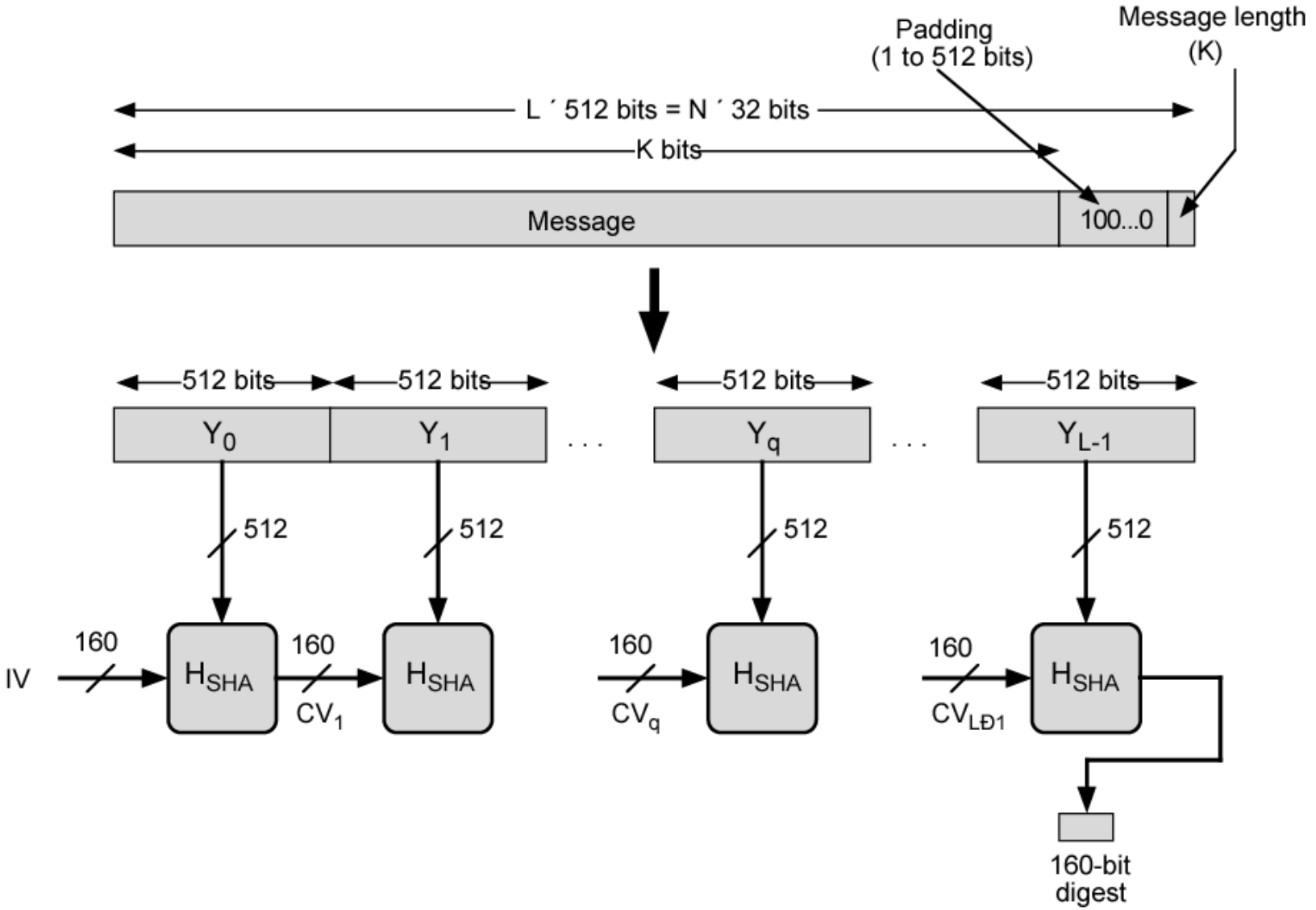
Message-Digest Algorithm 5 (MD5)

- Developed by Ron Rivest in 1991
- Uses 128-bit hash values
- Still widely used in legacy applications although considered insecure

Secure Hash Algorithm (SHA)

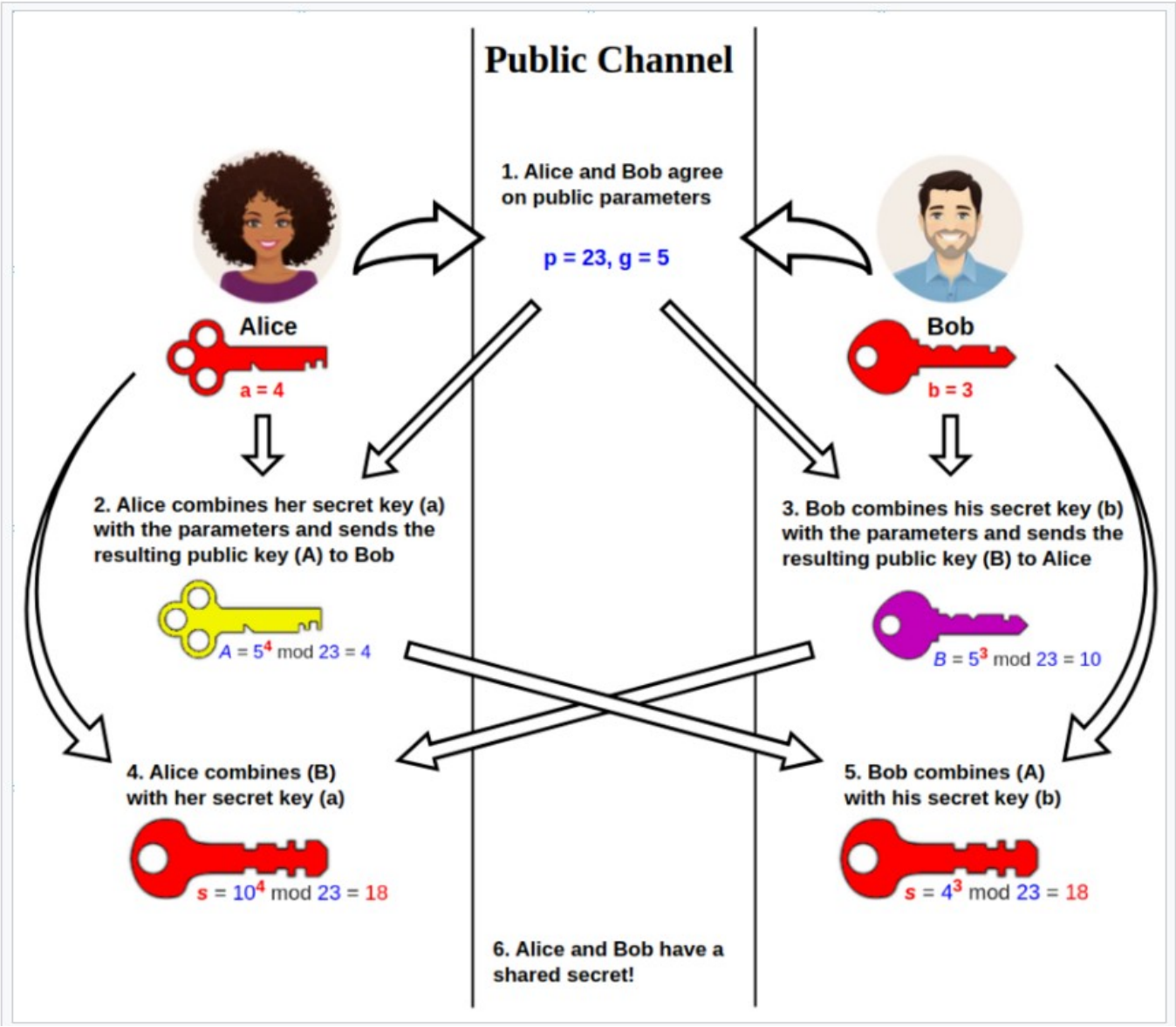
- Developed by NSA and approved as a federal standard by NIST
- SHA-1 (1993)
  - Input message less than 2^{64} bits: Processed in 512 bit blocks
  - Outputs 160-bits digest, considered insecure
  - Vulnerabilities less severe than those of MD5
- SHA-2 family (2002)
  - 256 bits (SHA-256) or 512 bits (SHA-512)
  - Still considered secure despite published attack techniques
- Public competition for SHA-3 announced in 2007

Message Digest generation (SHA-1)



Diffie Hellman Key Exchange

DH Key Exchange



https://en.wikipedia.org/wiki/Diffie%E2%80%93Hellman_key_exchange

Diffie-Hellman Key Exchange

- It is a mathematical method of securely generating a symmetric cryptographic key over a public channel
- Traditionally, secure encrypted communication required that they first exchange keys by some secure physical means, such as paper key lists transported by a trusted courier.
- DH method allows two parties that have no prior knowledge of each other to jointly establish a shared secret key over an insecure channel.

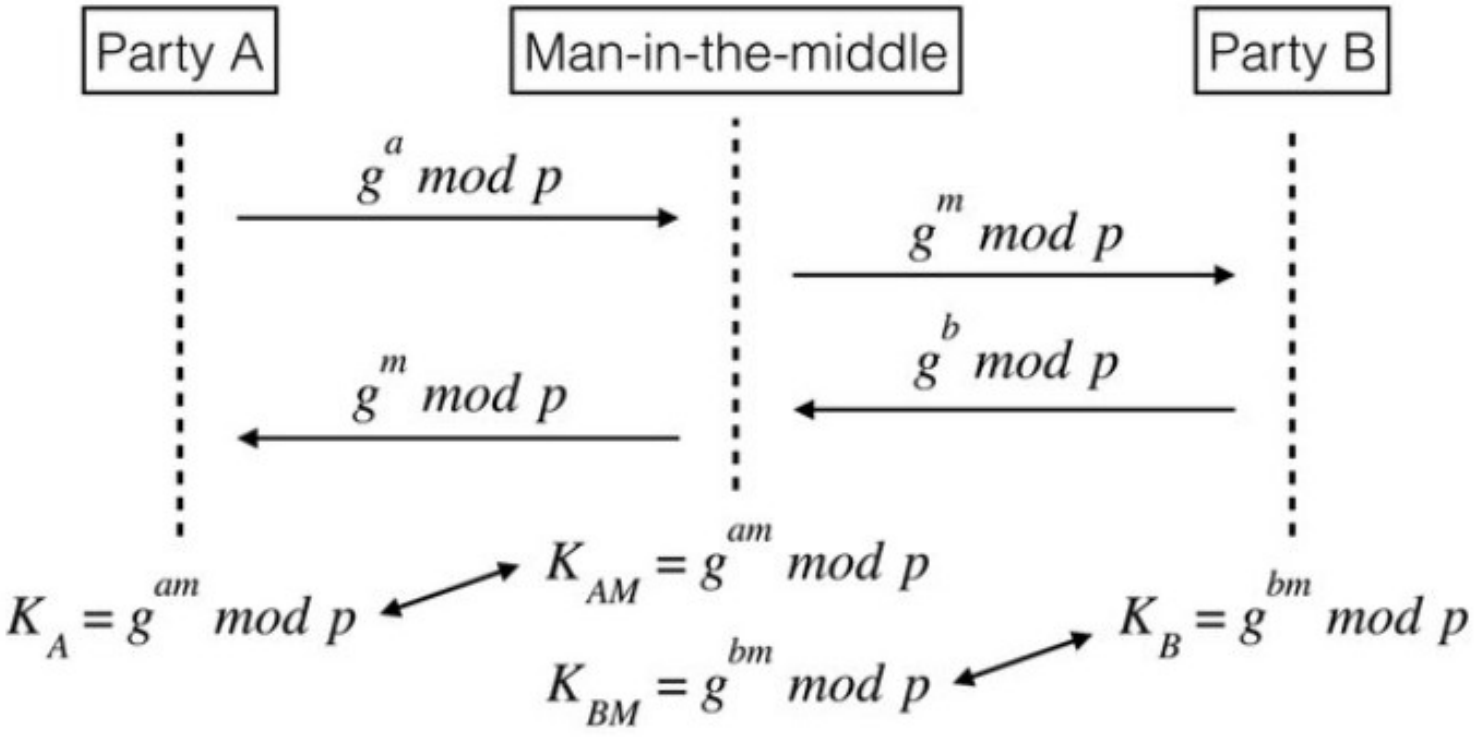
MITM on DH key Exchange

Man-in-the-Middle Attack The protocol depicted in Figure 21.8 is insecure against a man-in-the-middle attack. Suppose Alice and Bob wish to exchange keys, and Darth is the adversary. The attack proceeds as follows:

1. Darth prepares for the attack by generating two random private keys X_{D1} and X_{D2} and then computing the corresponding public keys Y_{D1} and Y_{D2}.
2. Alice transmits Y_A to Bob.
3. Darth intercepts Y_A and transmits Y_{D1} to Bob. Darth also calculates $K2 = (Y_A)^{X_{D2}} \bmod q$.
4. Bob receives Y_{D1} and calculates $K1 = (Y_{D1})^{X_B} \bmod q$.
5. Bob transmits Y_B to Alice.
6. Darth intercepts Y_B and transmits Y_{D2} to Alice. Darth calculates $K1 = (Y_B)^{X_{D1}} \bmod q$.
7. Alice receives Y_{D2} and calculates $K2 = (Y_{D2})^{X_A} \bmod q$.

At this point, Bob and Alice think that they share a secret key, but instead Bob and Darth share secret key $K1$ and Alice and Darth share secret key

MITM on DH


Party A
Man-in-the-middle
Party B
$g^{a} \bmod p$
$g^{m} \bmod p$
$g^{m} \bmod p$
$g^{b} \bmod p$
$K_{AM} = g^{am} \bmod p$
$K_{A} = g^{am} \bmod p$
$K_{BM} = g^{bm} \bmod p$
$K_{B} = g^{bm} \bmod p$

Digital Signature

Digital Signatures

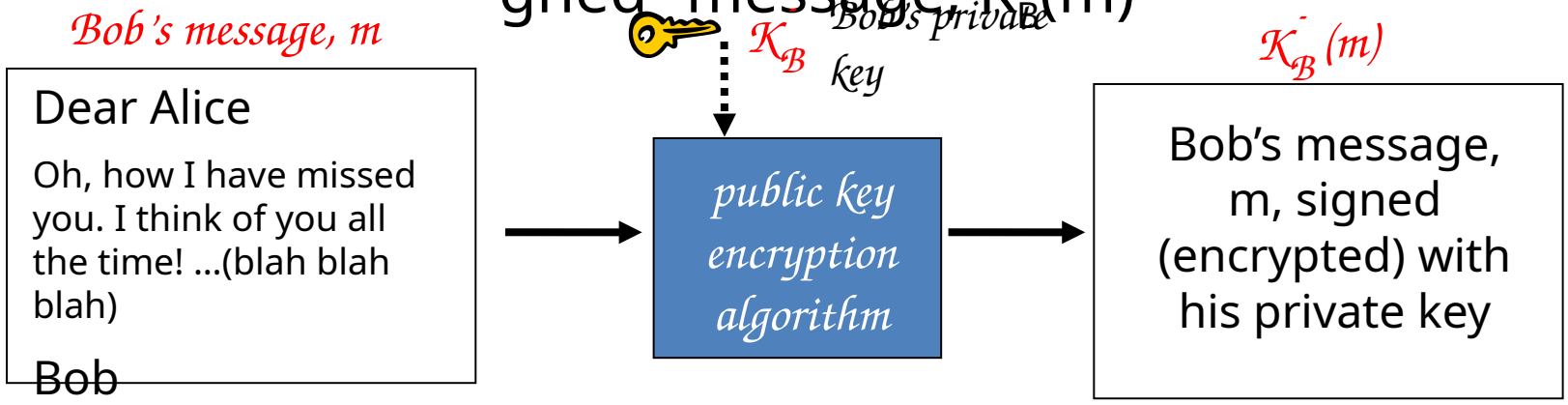
Cryptographic technique analogous to hand-written signatures.

- sender (Bob) digitally signs document, establishing he is document owner/creator.
- Verifiable, nonforgeable: recipient (Alice) can prove to someone that Bob, and no one else (including Alice), must have signed document

Digital Signatures

simple digital signature for message m:

- Bob "signs" m by encrypting with his private key K_B^-, creating "signed" message, $K_B^-(m)$



Digital Signatures (more)

- suppose Alice receives msg m, digital signature $K_B^-(m)$
- Alice verifies m signed by Bob by applying Bob's public key K_B^+ to $K_B^-(m)$ then checks $K_B^+(K_B^-(m)) = m$.
- if $K_B^+(K_B^-(m)) = m$, whoever signed m must have used Bob's private key.

Alice thus verifies that:

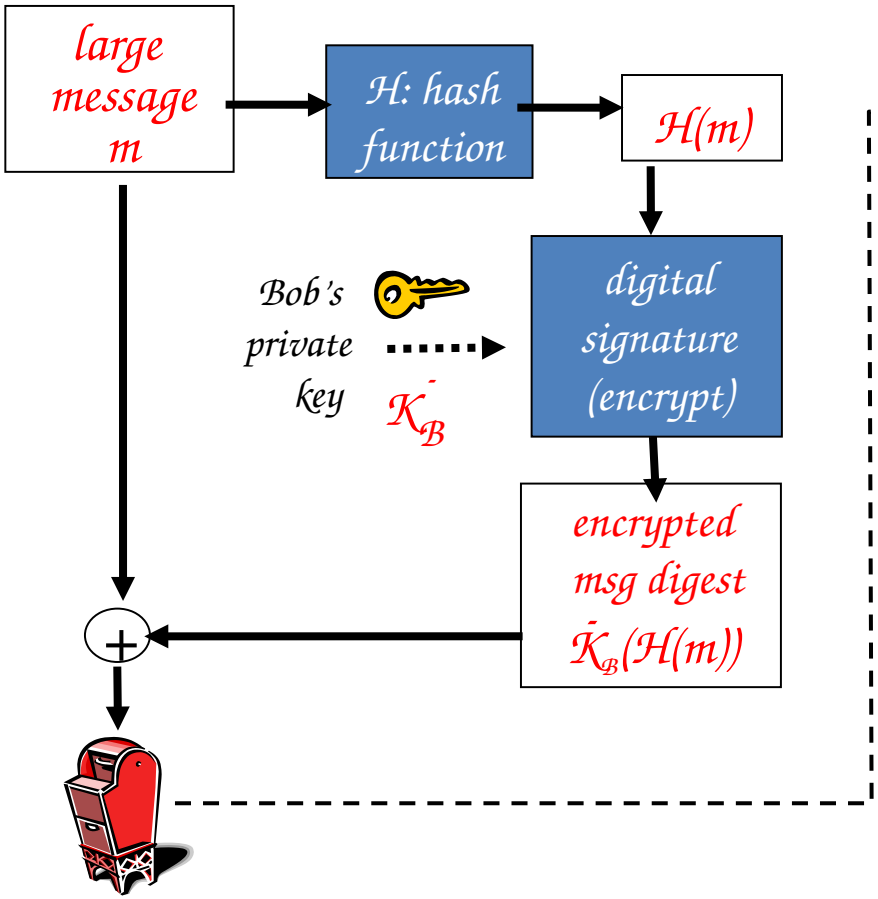
- Bob signed m.
- No one else signed m.
- Bob signed m and not m'.

non-repudiation:

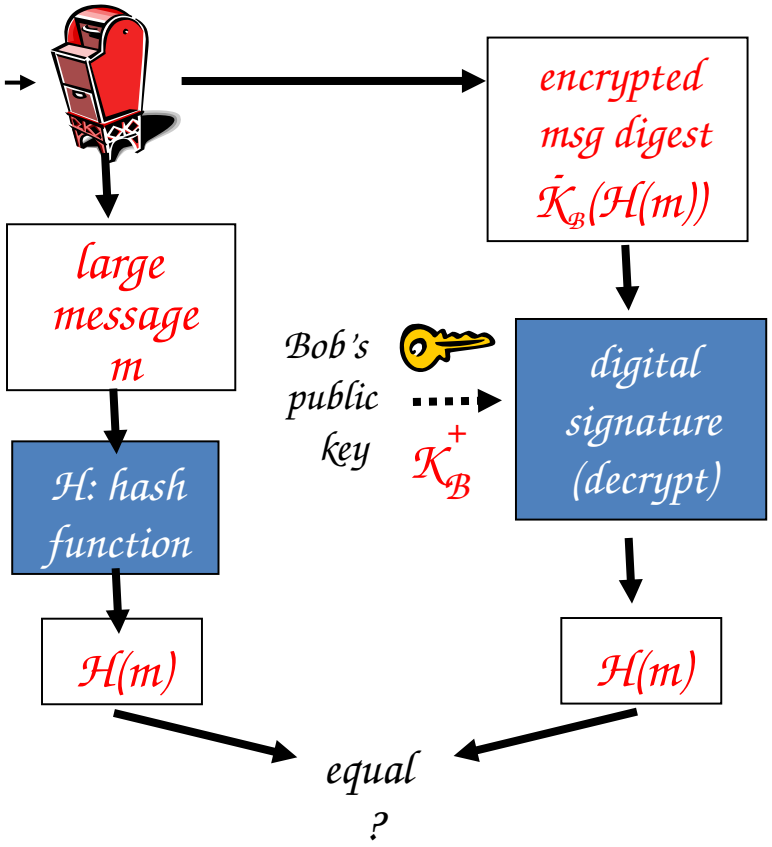
- ✓ Alice can take m, and signature $K_B^-(m)$ to court and prove that Bob signed m.

Digital signature = signed MAC

Bob sends digitally signed message:



Alice verifies signature and integrity of digitally signed message:



Public Key Certification

Public key problem:

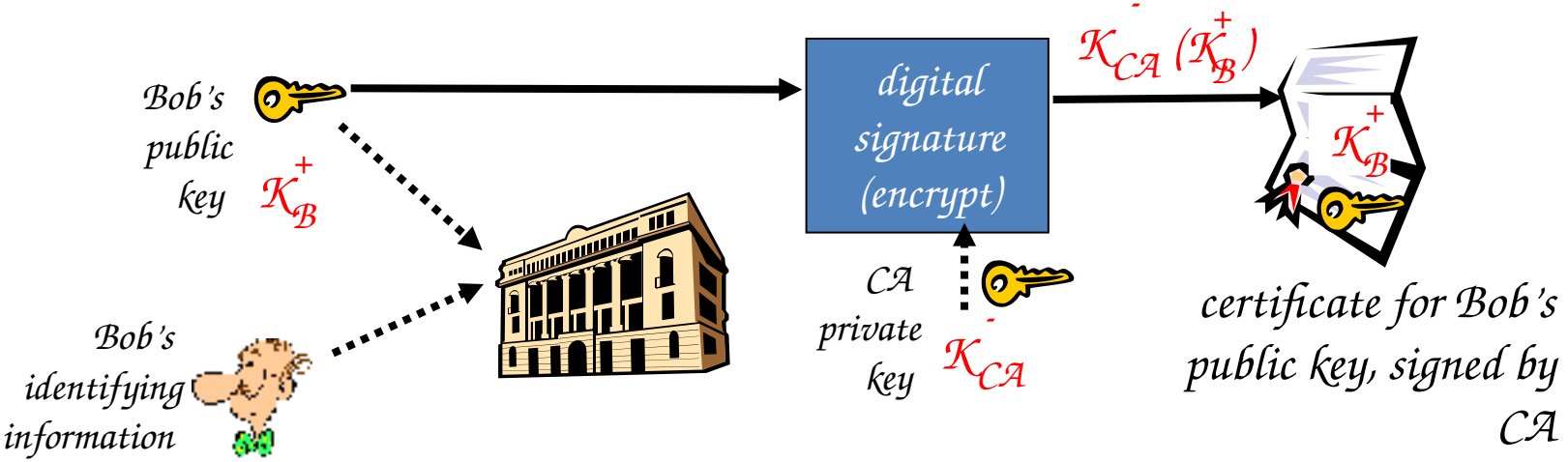
- When Alice obtains Bob's public key (from web site, e-mail, diskette), how does she *know* it is Bob's public key, not Trudy's?

solution:

- trusted certification authority (CA)

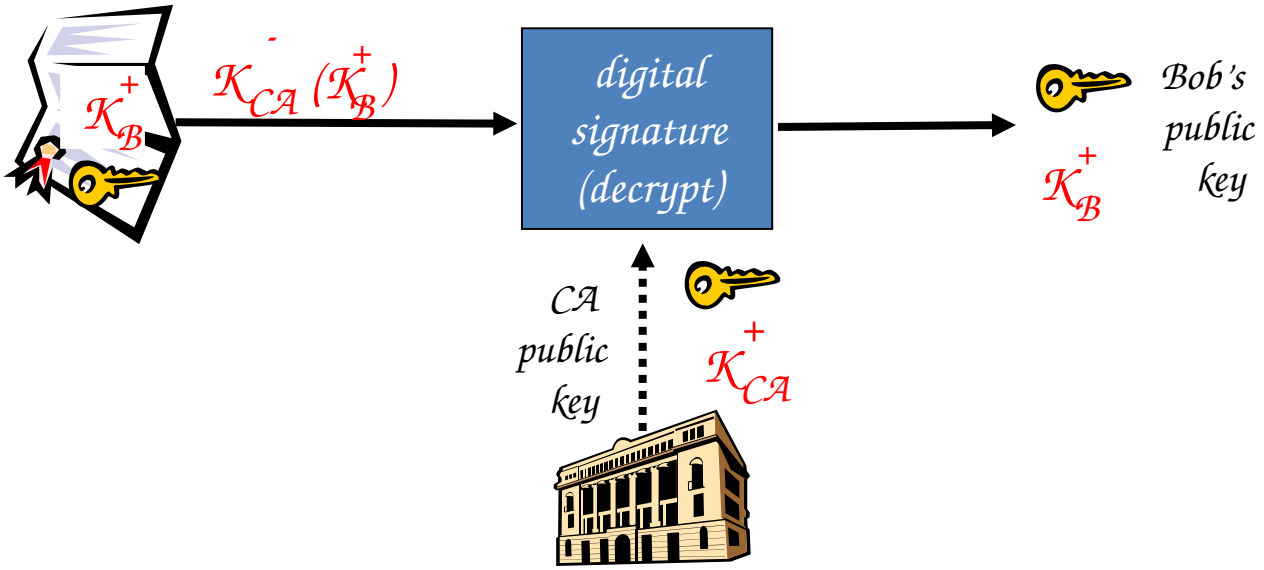
Certification Authorities

- Certification Authority (CA): binds public key to particular entity, E.
- E registers its public key with CA.
  - E provides “proof of identity” to CA.
  - CA creates certificate binding E to its public key.
  - certificate containing E’s public key digitally signed by CA: CA says “This is E’s public key.”



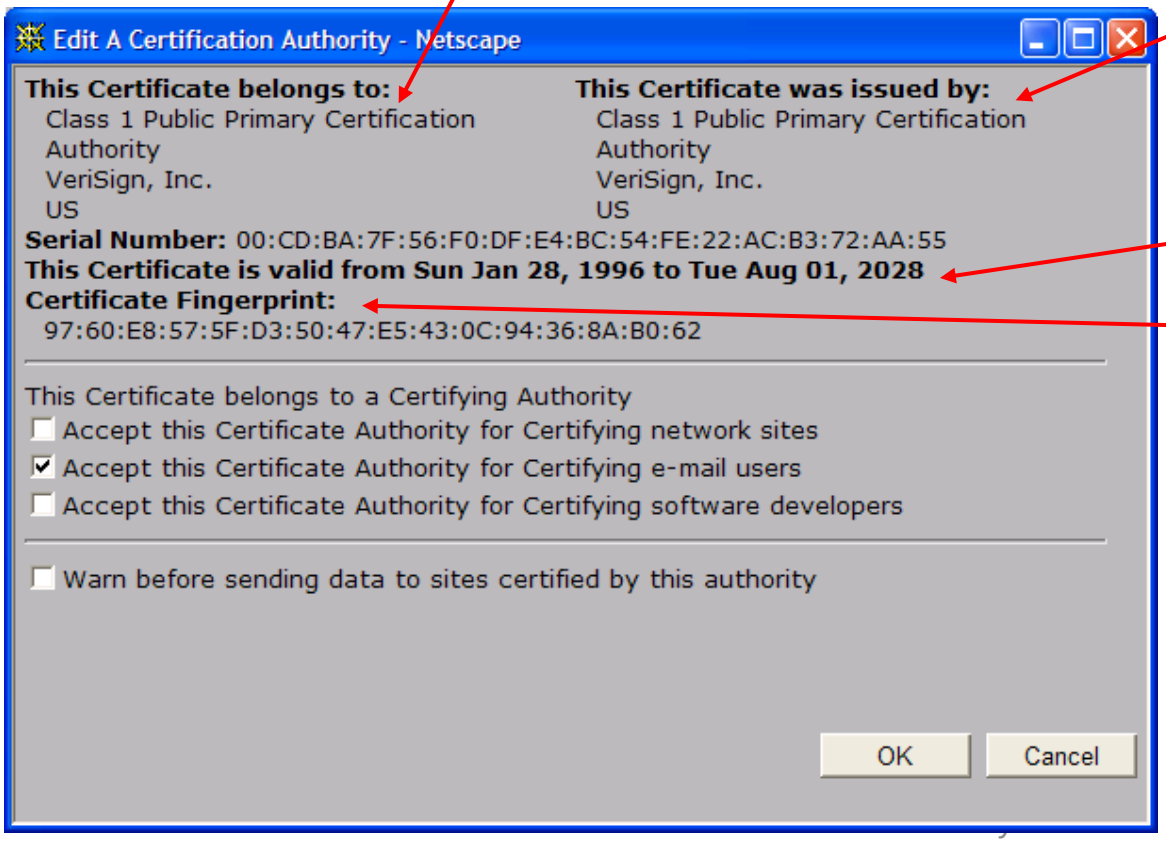
Certification Authorities

- when Alice wants Bob's public key:
  - gets Bob's certificate (Bob or elsewhere).
  - apply CA's public key to Bob's certificate, get Bob's public key



A certificate contains:

- Serial number (unique to issuer)
- info about certificate owner, including algorithm and key value itself (not shown)



- *info about certificate issuer*
- *valid dates*
- *digital signature by issuer*